Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-27 09:00 WIB

Top 5 Highlights

• Brotli2Shell: Frequently asked questions for Google Brotli decoder vulnerability (CVE-2026-111497)

• So Many AI Security Benchmarks, But None Tell the Whole Story

• Apple Patches for October 2026, (Mon, Oct 26th)

• VU#701544: mpc-lib Hardened Derivation Fails to Protect Ancestor Isolation

• Dutch police arrest two men over AI-powered bank fraud scheme

Threat Intelligence (10)

01. Worm armed 42 GitHub repos by hiding a payload too big to fail

Payload blobs measuring 12.9 to 13.7 MB were large enough to evade GitHub code search

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.theregister.com/security/2026/10/26/worm-armed-42-github-repos-by-hiding-a-payload-too-big-to-fail/5305570

02. LiteLLM supply chain attack started with an exposed master key

A 'strong illustration of the risks associated with failing to rotate a potentially exposed key'

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.theregister.com/security/2026/10/26/litellm-supply-chain-attack-started-with-an-exposed-master-key/5305544

03. Hackers Infect 953 Online Stores With Scanner-Evading JavaScript, Mostly on Magento

An unknown threat actor has infected 953 online stores, most of them running Magento, as part of a long-running campaign active since July 2025. According to Dutch e-commerce security company Sansec, the activity is designed to add a small piece of code to the store's pages that, when visited by unsuspecting users, serves malicious JavaScript loader code th…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/hackers-infect-953-online-stores-with.html

04. 'Gheist' Weaponizes GitHub Tokens to Steal Cloud Secrets

An ongoing supply chain attack is harvesting credentials and sensitive data from thousands of developer repositories.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: https://www.darkreading.com/cyberattacks-data-breaches/gheist-stolen-github-tokens-cloud-secrets

05. 953 Online Stores Infected in Long-Lasting Malware Campaign

Small loader code injected into the stores served a payload to visitors or did nothing to avoid detection. The post 953 Online Stores Infected in Long-Lasting Malware Campaign appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.securityweek.com/953-online-stores-infected-in-long-lasting-malware-campaign/

06. [+24h Old] uCreator Android Spyware Can Steal Telegram 2FA Passwords and Clone WeChat Accounts

A rentable Android spyware kit called uCreator takes over Telegram and WeChat accounts by hiding its code inside working copies of the two apps, researcher Ovi found. It only reaches people who install one of these tampered copies, spread outside the official app stores, or who run WeChat inside the kit makers' own container app. The kit's Telegram part mat...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/ucreator-android-spyware-can-steal.html

07. [+24h Old] Microsoft 365 Token-Replay Attacks Compromise 97 Accounts at 79 Organizations

Cybersecurity researchers have disclosed a Microsoft 365 campaign that has been observed leveraging an adversary-in-the-middle (AitM) relay to capture sign-in sessions and then replay the stolen tokens to break into email accounts at 79 organizations. Huntress, which observed the activity between July 14 and September 22, 2026, said it detected 497 successf...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/microsoft-365-token-replay-attacks.html

08. [+24h Old] Malicious File in Downloads Folder Tries to Trick AI Coding Agent Into Installing Malware

A malicious instruction file sitting in a developer's Downloads folder tried to make their AI coding agent install a known-malicious npm package, security firm Forever Security said in a report published last week. The company caught the attempt on a real customer's machine and stopped the agent before any code ran. It could not determine how the file got i...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/malicious-file-in-downloads-folder.html

09. [+24h Old] ISC Stormcast For Monday, October 26th, 2026 https://isc.sans.edu/podcastdetail/10150, (Mon, Oct 26th)

ISC Stormcast For Monday, October 26th, 2026 https://isc.sans.edu/podcastdetail/10150, (Mon, Oct 26th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33456

10. [+48h Old] Researchers Push Over 2 Million Updates to Remotely Disable Popcorn Time Updater That Could Fuel a Botnet

Between November 2025 and March 2026, the Dutch security firm Eye Security pushed more than 2 million updates to computers it did not own to switch off a background updater that it said could have allowed an outsider to take over the machine. The updater belongs to Time4Popcorn, an abandoned copy of Popcorn Time, a free app that streamed pirated films and T…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/researchers-push-over-2-million-updates.html

Latest Vulnerabilities (10)

01. Brotli2Shell: Frequently asked questions for Google Brotli decoder vulnerability (CVE-2026-111497)

Researchers have demonstrated remote code execution through CVE-2026-111497, an out-of-bounds write in Google's Brotli decoder library, and public proofs-of-concept (PoCs) are available. Software that uses the decoder includes Node.js,.NET, Bun, Envoy Proxy, Istio, Python HTTP clients and PHP for Windows. Key Takeaways CVE-2026-111497, known as Brotli2Shell…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.tenable.com/blog/brotli2shell-frequently-asked-questions-for-google-brotli-decoder-vulnerability-cve-2026

02. So Many AI Security Benchmarks, But None Tell the Whole Story

Measuring AI model security gets complex fast - a growing patchwork of benchmarks targets different variables in the equation, but none replace testing against your own code and workflows.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/cybersecurity-analytics/benchmarking-security-of-ai-models-poses-challenges

03. Apple Patches for October 2026, (Mon, Oct 26th)

Apple today released patches for 304 vulnerabilties. This number is still in line with prior Apple updates, and comes just about a month after the last apple update.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://isc.sans.edu/diary/rss/33458

04. VU#701544: mpc-lib Hardened Derivation Fails to Protect Ancestor Isolation

Overview Fireblocks' mpc-lib library contains a cryptographic fail-open vulnerability in its BIP32 hardened derivation implementation in the case of a missing private parent key. This breaks the ancestor isolation property of hardened derivation, allowing an attacker with a compromised lower-level signer share to recover the higher-level share it was derive...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://kb.cert.org/vuls/id/701544

05. In-the-Wild Attack Abuses AI Agents' Trust in Markdown

A new AI agent prompt injection technique exploits how coding assistants consume local instruction files, blurring the line between text documents and executable actions.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/application-security/in-the-wild-attack-ai-agents-trust-markdown

06. PHP2Shell exploitation confirmed, but mass attacks remain elusive

PHP2Shell exploits are emerging, but widespread attacks remain unconfirmed as scanning surges.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/news/php2shell-exploitation-confirmed-but-mass-attacks-remain-elusive

07. Discover and remediate PHP2Shell exposure with Tenable

Learn how to use Tenable solutions to find vulnerable PHP versions, prioritize remediation, and patch the critical PHP2Shell vulnerabilities (CVE-2026-109618 and CVE-2026-109619) faster. Key takeaways The PHP2Shell vulnerabilities (CVE-2026-109618 and CVE-2026-109619) put security teams in a race against attackers. PHP runs on more than 70% of websites, s...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.tenable.com/blog/discover-and-remediate-php2shell-exposure-with-tenable

08. DreamHost forces password resets in ongoing "incident"

DreamHost has forced password resets for email and FTP/SFTP users following an incident that disrupted connections to the File Manager interface. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/dreamhost-forces-email-ftp-sftp-password-resets-in-ongoing-incident/

09. VU#128947: COVESA vsomeip excessive memory allocation in reliable (TCP) endpoint buffer handling

Overview vsomeip, COVESA's open source implementation of the SOME/IP automotive communication middleware, contained a memory allocation vulnerability present in versions 3.7.3 and below. A vsomeip reliable (TCP) SOME/IP endpoint grows its receive buffer to an attacker-declared message size before validating that the declared bytes have actually been receive...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://kb.cert.org/vuls/id/128947

10. Microsoft releases emergency .NET security fixes for Google Brotli bug

Redmond joins growing list of software maintainers scrambling to patch compression flaw

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/26/microsoft-releases-emergency-net-security-fixes-for-google-brotli-bug/5305515

Data Breach & Cybercrime (10)

01. Dutch police arrest two men over AI-powered bank fraud scheme

Security Affairs reports that Dutch authorities apprehended two individuals involved in a sophisticated bank fraud operation utilizing artificial intelligence to deceive victims.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/dutch-police-arrest-two-men-over-ai-powered-bank-fraud-scheme

02. UK Biobank prepares to reopen research platform following major data breach

As outlined in The Register, the UK Biobank is preparing to restore access to its research analysis platform following a significant security breach that exposed the health data of 500,000 volunteers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/uk-biobank-prepares-to-reopen-research-platform-following-major-data-breach

03. University of Copenhagen data breach exposes data of 525,000 people

The University of Copenhagen in Denmark confirmed that hackers accessed one of its test environments containing personal data belonging to 525,000 people. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/university-of-copenhagen-data-breach-exposes-data-of-525-000-people/

04. Former pentester used ARTEX AI to steal 8.2 million data records

South Korean police identified seven suspects linked to a cybercrime operation that breached more than 90 organizations in the country, with ARTEX AI pentesting framework used in most of the attacks. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/former-pentester-used-artex-ai-to-steal-82-million-data-records/

05. 26th October - Threat Intelligence Report

For the latest discoveries in cyber research for the week of 26th October, please download our Threat Intelligence Bulletin. TOP ATTACKS AND BREACHES Japanese cloud hosting provider Onamae Desktop Cloud has confirmed a cyberattack in which intruders compromised its infrastructure and installed malware on customer servers. More than 26,000 servers were poten…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://research.checkpoint.com/2026/26th-october-threat-intelligence-report/

06. Attackers Use Microsoft Teams IT Support Scams to Deploy Malware and Ransomware

Cybersecurity researchers are calling attention to what they say is a "recurring social engineering pattern" across hundreds of cases in which threat actors use Microsoft Teams' external chat creation feature to conduct impersonation scams or to deliver malware. "A consistent pattern of attacker behavior has emerged across these incidents: the use of the sa…

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://thehackernews.com/2026/10/attackers-use-microsoft-teams-it.html

07. Gheist Attackers Stumble in Attempt to Abuse GitHub Tokens

A large-scale GitHub campaign abused stolen access tokens to target 13,500+ branches and repositories with secret-stealing workflows

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/gheist-attackers-abuse-stolen/

08. Stolen AI Reasoning Could Help China Build Cheaper Rivals

Xint says a flaw in OpenAI’s compaction process let researchers move reasoning traces between models, potentially making it cheaper to distill a rival AI. The post Stolen AI Reasoning Could Help China Build Cheaper Rivals appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/stolen-ai-reasoning-could-help-china-build-cheaper-rivals/

09. Chinese man extradited for role in $36 million cryptocurrency scam

A Chinese national was arraigned in California after being extradited from the Netherlands for his alleged involvement in a cryptocurrency investment scam that stole nearly $37 million from 174 victims in the United States. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/chinese-man-extradited-for-role-in-36-million-cryptocurrency-scam/

10. Dutch Police Arrest Two Over NFC Relay Attacks That Drained $400,000+ From Bank Accounts

The individuals called victims and persuaded them to install an app and scan their credit cards to loot their bank accounts. The post Dutch Police Arrest Two Over NFC Relay Attacks That Drained $400,000+ From Bank Accounts appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/dutch-police-arrest-two-over-nfc-relay-attacks-that-drained-400000/